

TAREA IC05

Documentación y comunicación de un incidente.

Autor: Carlos España Del Pozo - CETI

Contenido

Blue Team (Let's defend).	3
Introducción: caso práctico (contexto, alerta inicial y primeras investigaciones).	3
Comunicaciones, notificación y gestión del incidente	7
Clasificación justificada del incidente (Taxonomía oficial)	7
Determinación del nivel de peligrosidad.....	8
Determinación del nivel de impacto	8
Obligación de notificar al CSIRT	9
Tabla de información a enviar al CSIRT.....	9
Notificaciones requeridas y frecuencia.....	10
Estado de cierre del incidente.....	11

Blue Team (Let's defend).

El equipo azul (blue team) en ciberseguridad se refiere a un equipo dedicado a la defensa de una organización contra posibles amenazas de seguridad cibernética. El blue team lleva a cabo actividades como la detección y respuesta a incidentes, la evaluación continua de la seguridad y la implementación de medidas de seguridad proactivas para prevenir futuros ataques. El objetivo del blue team es proteger los sistemas y datos de la organización, manteniendo un alto nivel de seguridad y disponibilidad.

La web “<https://letsdefend.io/>” es una plataforma que ofrece soluciones y servicios en el ámbito de la ciberseguridad, como la formación y el entrenamiento en habilidades técnicas para la defensa cibernética, así como pruebas de penetración y evaluaciones de seguridad para empresas y organizaciones.

Introducción: caso práctico (contexto, alerta inicial y primeras investigaciones).

“Eres parte del equipo de ciberseguridad (SOC) de la sede del Ministerio de Justicia en Andalucía. Un día recibes una llamada urgente del responsable de TI: se han detectado eventos anómalos en un servidor corporativo y existe la sospecha de un ataque web en curso contra un servicio interno crítico (portal documental).

Al revisar el SIEM, aparece una alerta ‘Critical’ asociada a un posible intento de explotación de vulnerabilidad sobre un servidor on-premise de SharePoint. Tu misión como analista SOC es clasificar el posible incidente, valorar peligrosidad e impacto y documentar las comunicaciones/notificaciones necesarias siguiendo la Guía Nacional de Notificación y Gestión de Ciberincidentes.”

Evidencia inicial: alerta SIEM:

Tabla A — Detalle del evento

Severidad	Critical
Fecha / hora	Jul 22, 2025 – 01:07 PM
Rule name	SOC342 – CVE-2025-53770 SharePoint “ToolShell” Auth Bypass and RCE
EventID	320
Tipo	Web Attack
Hostname	SharePoint01
Source IP	107.191.58.76
Destination IP	172.16.20.17
HTTP method	POST
Requested URL	/_layouts/15/ToolPane.aspx?DisplayMode=Edit&a=/ToolPane.aspx

User-Agent	Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:120.0) Gecko/20100101 Firefox/120.0
Referer	/_layouts/SignOut.aspx
Content-Length	7699
Motivo del disparo	POST no autenticado a ToolPane.aspx, payload grande y referer “spoofed”, indicativo de explotación CVE-2025-53770.

Evolución de la investigación: primeras evidencias recopiladas por el SOC

*Tras revisar la alerta en el SIEM, el equipo inicia el triaje del evento para confirmar si se trata de un simple intento o de un compromiso real. En los primeros minutos se revisan registros del servidor web, trazas de red y métricas de disponibilidad del servicio. Con esa revisión inicial se obtiene la siguiente información **preliminar** (ficticia), que servirá como base para **clasificar el incidente**, **estimar peligrosidad e impacto** y **determinar las comunicaciones y notificaciones** que procedan.*

Tabla B — Contexto del organismo y hallazgos iniciales:

Servicio afectado	Portal documental interno (SharePoint) para tramitación y gestión de expedientes
Usuarios	~600 usuarios internos; pico ~300 simultáneos
Criticidad	Servicio importante (impacta la operativa diaria)
Alcance técnico	Granja pequeña: 2 frontales web + 1 SQL + 1 app (SharePoint01 es frontal web)
Evidencias complementarias (SOC)	1) Pico de 120 POST similares desde la misma IP en 6 minutos. 2) Tras el evento, SharePoint01 inicia conexiones salientes HTTPS a 107.191.58.76:443 durante 3 minutos (5 intentos). 3) No hay confirmación de exfiltración, pero sí indicio de posible compromiso de aplicación .
Disponibilidad	Servicio degradado ~70 minutos (errores intermitentes). Afectación estimada ~35% usuarios en ese periodo.
Datos potencialmente expuestos	Documentos con datos personales (DNI, direcciones, resoluciones) de contexto sensible por el ámbito de Justicia (sin clasificar “SECRETO”).
Medidas iniciales aplicadas	Bloqueo temporal de IP origen en WAF/Firewall; aislamiento de salida a Internet del frontal SharePoint01; preservación de logs IIS y eventos del sistema.
Estado al inicio	En investigación / no resuelto

Actividad principal: comunicaciones, notificación y gestión del incidente según la guía nacional de notificación y gestión de ciberincidentes presente en la documentación de la unidad.

Elabora un documento con el resultado de tu trabajo, basándote en la **Guía Nacional de Notificación y Gestión de Ciberincidentes** (especialmente apartados 5 y 6). Debes **justificar** todas las decisiones usando los criterios de la guía y las evidencias de las Tablas A y B.

1 Clasificación justificada del incidente (taxonomía oficial):

- 1) Clasifica el suceso según la taxonomía oficial (elige **una clasificación principal**).
- 2) Si aplica, indica clasificaciones secundarias (solo si las evidencias lo respaldan).
- 3) Justifica tu decisión citando qué elementos del caso (Tablas A y B) te llevan a esa clasificación.

2 Determinación del nivel de peligrosidad:

- 1) Asigna un nivel: **CRÍTICO / MUY ALTO / ALTO / MEDIO / BAJO**.
- 2) Justifica tu elección en función de los criterios oficiales de peligrosidad.
- 3) Si el suceso encaja en varias tipologías, prioriza la de **mayor peligrosidad**.

3 Determinación del nivel de impacto:

- 1) Asigna un nivel: **CRÍTICO / MUY ALTO / ALTO / MEDIO / BAJO / SIN IMPACTO**.
- 2) Justifica tu elección usando: afectación a usuarios, duración, criticidad del servicio, posible compromiso de información, etc. (Tabla B).
- 3) Relaciona tu decisión con los criterios oficiales de impacto.

4 Obligación de notificar al CSIRT correspondiente.

- 1) Indica el CSIRT de referencia aplicable para un organismo del sector público y explica el motivo.
- 2) Determina si la notificación es **obligatoria** o **potestativa**, en función de peligrosidad/impacto y el ámbito aplicable.

5 Tabla de información a enviar al CSIRT (plantilla a completar).

Rellena la tabla con la información que se remitiría en una **notificación inicial** (con lo conocido en ese momento), basándote en los campos recomendados por la guía.

Tabla C — Plantilla de notificación al CSIRT (rellenar)

Asunto	
Organismo notificante	
Sector	
Fecha y hora del incidente (UTC)	
Fecha y hora de detección (UTC)	
Descripción detallada	
Recursos tecnológicos afectados (IPs, roles, versiones si se conocen)	
Origen del incidente (si se conoce)	

Taxonomía (clasificación)	
Nivel de peligrosidad	
Nivel de impacto	
Impacto transfronterizo (sí/no + detalle)	
Plan de acción / contramedidas aplicadas	
Afectación (usuarios/sistemas/servicio)	
Medios necesarios (Jornadas-Persona estimadas)	
Impacto económico estimado (si aplica)	
Extensión geográfica	
Daños reputacionales (si aplica)	
Adjuntos (logs, capturas, etc.)	
Regulación afectada (ENS/RGPD/NIS/PIC/Otros)	
¿Se requiere actuación FFCCSE? (sí/no + motivo)	

6 Notificaciones requeridas y frecuencia.

- 1) Indica cuántas notificaciones proceden: **inicial, intermedia, final**.
- 2) Especifica los **plazos** aplicables según la “ventana temporal de reporte” (en función del nivel asignado).
- 3) Explica (4–6 líneas) qué tipo de información se actualizaría en una notificación intermedia (no redactar la notificación completa).

Evolución final del incidente (salto temporal)

*Han transcurrido **10 días naturales** desde la detección inicial. Tras las acciones de contención y análisis, el equipo SOC dispone ya de resultados suficientes para **cerrar el incidente**. A continuación, se incluyen los **hallazgos finales** (ficticios) que deberás usar para documentar el cierre y las comunicaciones finales.*

Tabla D — Hallazgos finales para el cierre:

Medidas aplicadas	Se aplicó la mitigación/parche recomendado para el vector del incidente y se verificó la versión/configuración del servicio.
Credenciales y accesos	Se rotaron credenciales de servicio y se revisaron permisos y cuentas con acceso a la granja.
Actividad posterior	No se observaron nuevos intentos con el mismo patrón (POST al endpoint afectado) desde el exterior tras el bloqueo inicial.
Persistencia	Revisión de integridad (archivos, tareas programadas, servicios) sin evidencias claras de persistencia.
Exfiltración	No hay evidencia confirmada de exfiltración (sin picos de salida sostenidos ni artefactos

	concluyentes). No obstante, no puede descartarse al 100% acceso a contenido durante la ventana inicial.
Disponibilidad	El servicio se mantiene estable desde hace 9 días (sin degradación ni incidencias relacionadas).

7 Estado de cierre del incidente.

- 1) A partir de los hallazgos finales (Tabla D), indica el **estado del cierre del incidente** identificando su **tipo de cierre** correspondiente.
- 2) Justifica el tipo de cierre elegido con evidencias del caso (Tablas A, B y D) y con los criterios de la guía.

Comunicaciones, notificación y gestión del incidente

A continuación, facilitamos el documento completo con el análisis, clasificación y notificación de un incidente de ciberseguridad detectado en nuestro organismo.

Clasificación justificada del incidente (Taxonomía oficial)

Clasificación principal:

Intento de Intrusión	Explotación de vulnerabilidades conocidas
-----------------------------	---

En base a los datos facilitados por nuestro SIEM **TABLA A**:

Rule name: "SOC342 – CVE-2025-53770 SharePoint Auth Bypass and RCE"

Motivo del disparo: POST no autenticado a ToolPane.aspx, payload grande y referer "spoofed", indicativo de explotación CVE-2025-53770.

La taxonomía de dicho incidente se describe como: Intento de compromiso de un sistema o de interrupción de un servicio mediante la explotación de vulnerabilidades con un identificador estandarizado (véase CVE).

Clasificación secundaria:

Disponibilidad	Degradación de servicio
-----------------------	-------------------------

En base a los datos facilitados por nuestro SIEM y la revisión posterior inicial **TABLA B**

Disponibilidad: Servicio degradado ~70 minutos (errores intermitentes). Afectación estimada ~35% usuarios en ese periodo.

No fue un DoS intencionado, pero hubo afectación real a la disponibilidad.

Determinación del nivel de peligrosidad

El incidente lo asociamos al siguiente nivel de peligrosidad:

ALTO

En base a los criterios oficiales de determinación de los niveles de peligrosidad de los ciberincidentes.

Intento de intrusión: Ataque desconocido / explotación

Intrusión: Compromiso de aplicaciones

Disponibilidad: DoS

Se aplica el criterio de mayor peligrosidad entre las diferentes tipologías siendo en este caso el mismo: **ALTO**.

Determinación del nivel de impacto

El incidente lo asociamos al siguiente nivel de impacto:

ALTO

En base a los criterios oficiales de determinación de los niveles de impacto de los ciberincidentes.

Servicio esencial	Impacta operativa diaria (Ministerio de Justicia)
Usuarios afectados	~600 usuarios; 35% afectados
Duración	70 minutos
Tipología de la información	Datos personales sensibles
Interrupción	Degradación significativa
Daño reputacional	Potencial alto en sector Justicia
Extensión geográfica	Andalucía

Se clasifica como **ALTO** por:

Interrupción en la prestación del servicio superior a 1 hora y superior al 10% de usuarios.

Daños reputacionales de difícil reparación, con eco mediático (amplia cobertura en los medios de comunicación) y afectando a la reputación de terceros.

Obligación de notificar al CSIRT

El incidente lo notificaremos a nuestro CSIRT de referencia en este caso nos corresponde:

CCN-CERT

Por los siguientes motivos:

Organismo público (Ministerio de Justicia)

En este caso la notificación es **obligatoria** porque la guía establece obligatoriedad cuando:

Nivel de peligrosidad $\geq$ **ALTO y/o afecte a organismos públicos**

Tabla de información a enviar al CSIRT

Asunto	Notificación inicial - Intento explotación CVE-2025-53770 en SharePoint corporativo
Organismo notificante	Ministerio de Justicia - Sede Andalucía
Sector	Administración Pública - Justicia
Fecha y hora del incidente (UTC)	Jul 22, 2025 – 01:07 PM
Fecha y hora de detección (UTC)	Jul 22, 2025 – 01:07 PM
Descripción detallada	Intento de explotación CVE-2025-53770 en servidor SharePoint mediante POST no autenticado a ToolPane.aspx. Se observan 120 intentos en 6 minutos desde IP externa. Posteriormente el servidor inicia conexiones salientes HTTPS hacia la IP origen. Servicio degradado 70 minutos.
Recursos tecnológicos afectados (IPs, roles, versiones si se conocen)	SharePoint01 (172.16.20.17), granja SharePoint (2 WFE + 1 SQL + 1 App). Servicio portal documental interno.
Origen del incidente (si se conoce)	IP 107.191.58.76 (externa)
Taxonomía (clasificación)	Intento de Intrusión - Explotación vulnerabilidad conocida (principal). Disponibilidad - Degradación de servicio(secundaria)
Nivel de peligrosidad	ALTO
Nivel de impacto	ALTO
Impacto transfronterizo (sí/no + detalle)	No
Plan de acción / contramedidas aplicadas	Bloqueo IP en WAF; aislamiento salida Internet; preservación logs; análisis forense en curso.
Afectación (usuarios/sistemas/servicio)	35% usuarios (~210 usuarios) durante 70 min. Servicio degradado.
Medios necesarios (Jornadas-Persona estimadas)	6–8 jornadas-persona estimadas

Impacto económico estimado (si aplica)	No estimado
Extensión geográfica	Andalucía
Daños reputacionales (si aplica)	Potenciales en caso de confirmarse acceso a datos
Adjuntos (logs, capturas, etc.)	Logs, eventos Windows, Logs SIEM, trazas red
Regulación afectada (ENS/RGPD/NIS/PIC/Otros)	ENS, RGPD
¿Se requiere actuación FFCCSE? (sí/no + motivo)	No por el momento

Notificaciones requeridas y frecuencia

Las notificaciones requeridas serán:

1. Notificación inicial (realizada)
2. Notificación intermedia (durante el transcurso de la investigación)
3. Notificación final (cierre)

Para nuestra incidencia de nivel **ALTO** reportaremos la notificación:

1. Inicial durante las primeras 24 horas.
2. Intermedia con avances significativos.
3. Final, al cierre de esta.

En la notificación intermedia nos encargaremos de actualizar los siguientes datos:

- Confirmación o descarte de compromiso de sistemas.
- Resultados preliminares de análisis forense.
- Estado del parcheado y mitigaciones de CVE.
- Evaluación más precisa de impacto.

Estado de cierre del incidente

Estado de cierre del incidente:

CERRADO	Resuelto y con respuesta
----------------	--------------------------

En base a los criterios oficiales de estados de los ciberincidentes, dicho cierre aplica cuando:

*El organismo afectado ha solventado la amenaza y notifica a su **CSIRT** de referencia el cierre del ciberincidente.*

El Ministerio de Justicia (SOC y equipo TI) comunicación y coordino con el **CSIRT**

- Aplicó mitigación/parche recomendado.
- Verificó versión y configuración del servicio.
- Rotó credenciales de servicio.
- Revisó permisos y cuentas con acceso.
- Aisló temporalmente el servidor afectado.
- Preservó evidencias.
- Monitorizó durante 9 días sin nuevos eventos.

Y la amenaza ha sido solventada como vemos en la tabla:

- No existen evidencias de persistencia.
- No se observan indicadores de compromiso activo.
- El servicio permanece estable desde hace 9 días.
- No hay evidencia confirmada de exfiltración.